

# HACKERS & HACKING METHODOLOGIES

## Cybersecurity Assignment

|                         |                              |
|-------------------------|------------------------------|
| <b>Student Name</b>     | _____                        |
| <b>Course / Program</b> | _____                        |
| <b>Subject</b>          | Cybersecurity                |
| <b>Submission</b>       | GitHub Assignment Submission |

## Introduction

This assignment explains common hacking methodologies, demonstrates a small offline four-digit PIN brute-force simulation, describes a phishing attack lifecycle, explains how fake login pages can be abused for credential harvesting, and reviews recent cybersecurity incidents involving Indian organizations, applications, or online services. The examples are presented for cybersecurity education and defensive awareness.

### Question 1

**List 3 common hacking methodologies (such as phishing, brute force, SQL injection) and for each, write one real-world example of how it could be used to compromise an account on an app like Instagram or Paytm.**

**Answer:** Three common methodologies are:

| Methodology   | How it works                                                                                                                                                                             | Example involving a popular app/service                                                                                                                                                                         |
|---------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Phishing      | The attacker creates a convincing message or fake website that tricks a victim into entering credentials, OTPs, or other sensitive information.                                          | A victim receives a fake Instagram security alert or a fake Paytm/KYC message. If the victim enters credentials on the fraudulent page, the attacker may obtain them.                                           |
| Brute Force   | The attacker repeatedly tries possible passwords or PINs until the correct credential is found. Modern services reduce this risk with rate limits, lockouts and MFA.                     | If an online account had weak password protection and no rate limiting, an attacker could repeatedly try common passwords. This is why strong unique passwords and MFA are important.                           |
| SQL Injection | An attacker attempts to manipulate an application's database query through unsafe input handling. Proper parameterized queries and input validation prevent this class of vulnerability. | If a vulnerable login or search function directly inserted user input into a database query, malicious input could potentially alter the query and expose or modify data. Secure coding practices prevent this. |

Important: The examples above describe attack concepts, not instructions for attacking real services. Real-world testing should only be performed on systems where the tester has explicit authorization.

### Question 2

**Simulate a simple brute force attack by writing a Python script that tries all 4-digit PIN combinations (0000–9999) to guess a preset password variable. Print the number of attempts taken to find the correct PIN.**

**Answer:** The following script is an offline educational simulation. It does not connect to Instagram, Paytm, or any other real service.

```
# Educational offline brute-force simulation
# This program tests a local 4-digit PIN only.

target_pin = "5832"
attempts = 0

for number in range(10000):
    guess = f"{number:04d}"
    attempts += 1

    if guess == target_pin:
```

```
        print("Correct PIN found:", guess)
        print("Number of attempts:", attempts)
        break
    else:
        print("PIN was not found.")
```

For the sample PIN 5832, the program will stop when it reaches that combination and print the total number of attempts. The simulation demonstrates why short PINs have a limited search space and why online systems should use rate limiting, account lockouts and additional authentication factors.

### Question 3

**Research and describe the steps involved in a phishing attack targeting users of a popular food delivery app like Zomato or Swiggy. Include at least 4 steps and explain what the attacker and victim do at each stage.**

**Answer:** A typical phishing scenario can be described in the following four stages:

#### 1. Preparation

Attacker: creates a fraudulent message that imitates a legitimate food-delivery notification, such as a coupon, refund, order problem, or account warning. Victim: has not yet interacted with the message.

#### 2. Delivery

Attacker: sends the message through email, SMS, social media, or another communication channel and may include a suspicious link. Victim: receives the message and may believe it is genuine because it uses familiar branding or urgent language.

#### 3. Credential Capture

Attacker: directs the victim to a fake page designed to resemble a legitimate login, payment, or verification page. Victim: may enter a username, password, card information, OTP, or other information without realizing the page is fraudulent.

#### 4. Misuse and Response

Attacker: attempts to misuse the captured information or sell it, depending on the campaign. Victim: should immediately stop interacting with the page, change affected passwords, enable MFA, contact the legitimate service through its official app/site, and report the phishing attempt.

Common warning signs include unexpected urgency, unusual URLs or domains, requests for passwords/OTPs, unexpected APK or file downloads, and offers that are unusually good. Users should open the official app directly instead of using suspicious links.

### Question 4

**Given the following fake login page HTML code, identify and explain two ways a hacker could use this page for credential harvesting. Hint: Think about what happens to the data entered by the user and how it could be sent to an attacker.**

**Answer:** Two common credential-harvesting mechanisms are:

#### Method 1: Sending submitted data to an attacker-controlled server

A fake login form can be designed so that the username and password entered by the victim are submitted to a remote server controlled by the attacker. The attacker could then store the submitted values and attempt to

reuse them. In a legitimate application, login credentials should be sent only to the real service over HTTPS and processed securely.

## Method 2: Capturing the data in browser-side code and forwarding it

Malicious JavaScript on a fake page can read values entered into form fields and transmit them elsewhere. This can happen when the user presses a Login or Submit button. Defenders can reduce this risk by avoiding untrusted pages, checking the domain carefully, using password managers, enabling MFA, and reporting suspicious pages.

Defensive lesson: A login page should be checked for the correct domain, HTTPS connection, expected certificate/security indicators, and normal authentication flow. Never enter passwords or OTPs into a page reached through an unexpected message.

## Question 5

**Use ChatGPT or another AI tool to generate a list of 5 recent real-world hacking incidents involving Indian apps or websites. For each incident, write one line about the hacking methodology used.**

**Answer:** Recent examples (2025–2026):

| Incident / Date                                                                          | What happened                                                                                                                                                                                 | Methodology / security issue                                                                                                                                                     |
|------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| UMANG portal security flaws — July 2026                                                  | Security researchers reported vulnerabilities in the UMANG government-services platform that could potentially expose sensitive information; government authorities responded to the reports. | Web application vulnerabilities / access-control weaknesses. The reporting concerned possible unauthorized access to data rather than a confirmed criminal breach.               |
| CBSE On Screen Marking portal claims — May 2026                                          | A researcher publicly claimed serious security weaknesses in CBSE's On Screen Marking system. CBSE rejected claims that its marking platform had been compromised.                            | Alleged web-application/security weaknesses. Because CBSE disputed the compromise claim, this should be treated as a reported vulnerability controversy, not a confirmed breach. |
| Cyberattack on Tata Electronics — June 2026                                              | Tata Electronics confirmed that it had identified a cybersecurity incident affecting parts of its IT infrastructure; the company said operations remained unaffected.                         | Cyberattack against corporate IT infrastructure. Public reporting did not establish enough technical detail to assign a specific exploit method.                                 |
| Bank of Baroda data-access incident — July 2026                                          | Bank of Baroda said an employee email account was compromised, leading to unauthorized access to certain data. The bank said its core banking systems were not accessed.                      | Account compromise / email compromise. The bank said the exact method used to compromise the employee account was still under investigation.                                     |
| DDoS campaign targeting Indian government websites — 2025 incident, investigated in 2026 | Authorities investigated attempted distributed-denial-of-service attacks against 54 Indian government websites and critical information infrastructure during Operation Sindoor.              | DDoS: attackers attempt to overwhelm online services with large volumes of traffic, reducing availability rather than directly stealing passwords.                               |

Note on accuracy: Some recent cases above were vulnerability reports, alleged compromises, or confirmed cyber incidents where the exact technical method was not publicly disclosed. They are labeled accordingly rather than being presented as confirmed hacking techniques when the evidence does not establish that.

## References / Sources

- **India Today (14 July 2026) — UMANG portal vulnerability report**  
<https://www.indiatoday.in/technology/news/story/umang-portal-flaw-may-have-exposed-aadhaar-linked-data-of-millions-govt-responds-2947356-2026-07-14>
- **Hindustan Times (27 May 2026) — CBSE OSM portal claims and CBSE response**  
<https://www.hindustantimes.com/india-news/cbse-rejects-osm-breach-claims-but-did-19-year-old-nisarga-adhikary-vulnerability-report-really-hack-marking-portal-101779859236685.html>
- **BleepingComputer (23 June 2026) — Tata Electronics cyberattack**  
<https://www.bleepingcomputer.com/news/security/tata-electronics-confirms-cyberattack-as-hackers-leak-data/>
- **India Today (27 July 2026) — Bank of Baroda employee email compromise**  
<https://www.indiatoday.in/technology/story/employee-email-compromise-led-to-unauthorised-data-release-core-banking-systems-secure-says-bank-of-baroda-2957315-2026-07-27>
- **Hindustan Times (25 August 2026) — DDoS case involving Indian government websites**  
<https://www.hindustantimes.com/india-news/nia-searches-five-locations-in-cyberattack-case-during-op-sindoor-101787598911084.html>
- **CERT-In — Cyber attack campaign targeting Indian ICT infrastructure**  
<https://www.cert-in.org.in/s2cMainServlet?VLCODE=CIAD-2023-0036&pageid=PUBVLNOTES02>
- **CERT-In — Essential measures for industry against cyber threats**  
<https://www.cert-in.org.in/s2cMainServlet?VLCODE=CIAD-2025-0019&pageid=PUBVLNOTES02>

## Conclusion

Hacking methodologies exploit weaknesses in people, passwords, applications, accounts, or infrastructure. Phishing demonstrates the human side of security, brute force demonstrates the importance of strong authentication and rate limiting, and SQL injection demonstrates the need for secure software development. Recent incidents also show why vulnerability management, access control, MFA, monitoring, incident response, and responsible disclosure are essential parts of cybersecurity.

## Types of Hackers – Assignment

### Task 1: Main Types of Hackers

| Type of Hacker                | Description                                                                                                                                                                                                                   | Real-World Example / News                                                                                                                                                                                                          |
|-------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>White Hat Hacker</b>       | A white hat hacker is an ethical hacker who has permission to test systems and find security weaknesses. Their goal is to help organizations improve security.                                                                | <b>Google Project Zero</b> regularly researches and reports serious software vulnerabilities so they can be fixed. For example, the team has published detailed research on zero-day vulnerabilities and exploits.                 |
| <b>Black Hat Hacker</b>       | A black hat hacker accesses systems without permission for harmful or illegal purposes, such as stealing information, money, or disrupting systems.                                                                           | <b>WannaCry ransomware (2017)</b> infected hundreds of thousands of computers in more than 150 countries, encrypted files, and demanded ransom.                                                                                    |
| <b>Gray Hat Hacker</b>        | A gray hat hacker may find or access a system without permission but may report the vulnerability rather than exploit it for criminal purposes. Because the access is unauthorized, it remains a legal and ethical gray area. | A researcher discovering a vulnerability in a company's website without authorization and then informing the company about it would be an example of gray-hat behavior.                                                            |
| <b>Script Kiddie</b>          | A script kiddie is a person with limited technical knowledge who uses existing hacking tools, scripts, or programs created by others rather than developing their own sophisticated attacks.                                  | A beginner downloading an existing DDoS or password-attack tool and using it against a website without understanding how the tool works is an example. CISA identifies script kiddies as a recognized category of cyber attackers. |
| <b>Hacktivist</b>             | A hacktivist uses hacking techniques to promote or draw attention to a social or political cause.                                                                                                                             | <b>Anonymous</b> is a well-known hacktivist collective associated with cyberattacks against various organizations and governments to promote political or social causes.                                                           |
| <b>State-Sponsored Hacker</b> | A state-sponsored hacker operates with the backing or direction of a government, commonly for espionage, intelligence gathering, disruption, or strategic objectives.                                                         | The <b>SolarWinds compromise</b> involved activity that U.S. agencies attributed to Russian SVR cyber operators, who used compromised SolarWinds software to gain access to targeted networks.                                     |

---

### Task 2: Hacker Scenarios – Instagram

App chosen: Instagram

## 1. White Hat Hacker

A white hat hacker would have permission from Instagram/Meta to test its security. For example, they might discover a vulnerability that could expose user information and responsibly report it to the company so it can be fixed.

## 2. Black Hat Hacker

A black hat hacker might try to steal Instagram passwords or take control of accounts without permission. They could then use the stolen accounts to scam users, steal information, or demand money.

## 3. Gray Hat Hacker

A gray hat hacker might discover a security weakness in Instagram without having permission to test that part of the system. They may report the vulnerability to the company afterward, but accessing the system without authorization can still violate rules or laws.

---

### Task 3: Classify the Actions

| Action                                        | Type of Hacker  | Reason                                                                                                                                                      |
|-----------------------------------------------|-----------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Reporting a bug to the company                | White Hat       | The person is helping the company identify and fix a security problem, typically with authorization or through an approved vulnerability-reporting process. |
| Stealing user data                            | Black Hat       | The person is accessing or taking information without authorization for malicious purposes.                                                                 |
| Testing your own account                      | White Hat       | You are testing a system/account that you own or are authorized to test.                                                                                    |
| Defacing a website for a political cause      | Hacktivist      | The attack is being used to promote or draw attention to a political or social cause.                                                                       |
| Participating in a government cyber operation | State-Sponsored | The activity is being conducted as part of a government-backed cyber operation.                                                                             |

---

### Task 4: Interview-Style Answer – Cricket Analogy

#### Question: What is the difference between a white hat and a black hat hacker?

Think of a cricket match. A **white hat hacker** is like a player who plays according to the rules and is officially allowed to participate in the match. They may test the opponent's weaknesses, but they do it within the rules and with permission. A **black hat hacker** is like someone who secretly enters the match, breaks the rules, and

tries to damage the other team's equipment or steal their score. So, the main difference is **permission, purpose, and whether the rules are being followed**.

### **Short conclusion**

Hackers are not all the same. **White hats** generally work to improve security, while **black hats** attack systems for harmful purposes. **Gray hats** operate without authorization but may have non-malicious intentions, **script kiddies** rely heavily on existing tools, **hacktivists** are motivated by social or political causes, and **state-sponsored hackers** operate with government backing.

## Cyber Security Threats

### Task 1: Five Different Types of Cyber Security Threats

| Cyber Security Threat | Description                                                                                                                                                  | Real-Life Example                                                                                                                         |
|-----------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------|
| 1. Phishing           | Phishing is when attackers send fake emails, messages, or links pretending to be a trusted person or company to steal passwords, OTPs, or other information. | A user receives a fake Instagram message saying, "Your account will be deleted. Click here to verify," and is taken to a fake login page. |
| 2. Malware            | Malware is malicious software designed to damage a device, steal information, or give an attacker unauthorized access.                                       | A user downloads a fake mobile application that secretly installs malware and steals personal information.                                |
| 3. Ransomware         | Ransomware locks or encrypts files and demands money from the victim to restore access.                                                                      | The <b>WannaCry attack in 2017</b> affected hundreds of thousands of computers worldwide and demanded ransom from victims.                |
| 4. DDoS Attack        | A Distributed Denial-of-Service (DDoS) attack sends huge amounts of traffic to a server so that a website or service becomes slow or unavailable.            | A website such as an online shopping or food-delivery service can become unavailable because attackers flood its servers with requests.   |
| 5. Account Takeover   | An attacker obtains someone's login credentials and uses them to gain control of their account.                                                              | A stolen Instagram password can allow an attacker to take over the account and send scam messages to the victim's followers.              |

---

### Task 2: Phishing Attack Scenario

#### App Chosen: Instagram

Imagine that a user receives an Instagram message saying:

**"Urgent! Your Instagram account has violated our community guidelines. Your account will be permanently deleted within 24 hours. Click here to verify your account."**

The link takes the user to a **fake Instagram login page** that looks almost identical to the real website. The user enters their username and password, and the attacker receives these credentials. The attacker can then attempt to access the victim's account.

#### How can the user identify the phishing attack?

1. **Check the URL carefully** – The website address may contain unusual spelling or a suspicious domain.

2. **Look for urgent language** – Messages saying “Act immediately” or “Your account will be deleted” are common phishing techniques.
  3. **Check the sender** – Verify whether the message actually comes from Instagram.
  4. **Never share passwords or OTPs** – Legitimate services should not ask users to send their passwords or OTPs through messages.
  5. **Look for spelling and grammar mistakes** – Fake messages often contain unusual wording or errors.
  6. **Use two-factor authentication (2FA)** – 2FA provides an additional layer of protection.
- 

### Task 3: Short Report on a Recent Cyber Attack

#### IRCTC Cybersecurity Incident – 2025

In 2025, cybersecurity concerns surrounding **IRCTC's Tatkal ticket-booking system** included the use of automated bots and unauthorized software to obtain tickets quickly. The issue was particularly important because Tatkal tickets are released at a specific time and are in high demand. Reports described automated tools being used to interact with the booking system faster than ordinary users, creating an unfair advantage and putting additional pressure on the service.

The threat in this case involved **automation abuse and unauthorized access to the booking process**, rather than a traditional ransomware attack. Cybersecurity and railway authorities have worked to identify suspicious activity, block unauthorized automation, strengthen CAPTCHA and authentication mechanisms, and improve monitoring of booking activity. IRCTC and Indian Railways have also taken measures against agents and users found violating ticket-booking rules.

This example shows that cybersecurity is not only about protecting passwords and databases. Systems must also defend against bots, automated abuse, fraud, and attempts to bypass normal user controls.

**Word count: approximately 160 words**

---

### Task 4: Cybersecurity Poster – Phishing

#### PHISHING

#### THINK BEFORE YOU CLICK!

**It only takes one click to lose your data!**

#### 1. HOW DOES PHISHING WORK?

**Fake Message → Fake Login Page → User Enters Credentials → Attacker Steals Information**

Attackers send fake emails, SMS messages, or social-media messages that appear to come from trusted companies. The link takes the victim to a fake website designed to steal usernames, passwords, OTPs, or other personal information.

## 2. WHO IS AT RISK?

- Instagram users
- WhatsApp users
- Banking users
- Online shopping users
- Students and employees
- Anyone who uses email or the Internet

## 3. RED FLAGS 🚩

- Urgent or threatening messages
- Suspicious links
- Misspelled website addresses
- Spelling or grammar mistakes
- Unexpected attachments
- Requests for passwords or OTPs
- Offers that seem too good to be true

## 4. HOW TO PREVENT PHISHING 🛡️

- **Check the URL carefully**
- **Never share your password or OTP**
- **Enable two-factor authentication**
- **Avoid clicking unknown links**
- **Verify the sender**
- **Use official apps and websites**
- **Keep your device and apps updated**

**REMEMBER:**

**STOP → CHECK → VERIFY → THEN CLICK**

## Footprinting & Information Gathering Assignment

**Note:** This assignment uses only publicly available information. The commands below are for learning and passive reconnaissance, not for attempting unauthorized access.

### Task 1: DNS Lookup of Flipkart

#### Command used

```
nslookup www.flipkart.com
```

#### Findings

The public DNS information currently lists the following IPv4 address for **flipkart.com**:

- **IPv4 / A record:** 163.53.76.86

Additional DNS information:

- **Name Servers (NS):**
  - sdns14.ultradns.biz
  - sdns14.ultradns.com
  - sdns14.ultradns.net
  - sdns14.ultradns.org
- **Mail servers (MX):**
  - eu-smtp-inbound-1.mimecast.com
  - eu-smtp-inbound-2.mimecast.com
- **SOA Primary Name Server:** pdns1.ultradns.net
- **SOA Responsible Party:** sysadmin.flipkart.com

These records are publicly observable DNS information. The reported IP/location can reflect CDN or hosting infrastructure rather than Flipkart's physical location.

#### Result

**Domain:** www.flipkart.com

**IP Address:** 163.53.76.86

**DNS Provider/Nameservers:** UltraDNS

---

### Task 2: Google Dorking – Public Instagram Profiles

#### Search query

Use the following Google search:

site:instagram.com "YOURCOLLEGE.ac.in"

For example, if the college domain were example.ac.in:

site:instagram.com "example.ac.in"

## Results

Because your question does **not specify your college domain**, I can't truthfully list the first 3 profiles without inventing results.

Use your actual college domain and record the first three **public** results in this format:

| No. | Instagram Profile | Why it appeared |
|-----|-------------------|-----------------|
|-----|-------------------|-----------------|

|   |                     |                                                               |
|---|---------------------|---------------------------------------------------------------|
| 1 | instagram.com/_____ | Public profile associated with the college domain/search term |
|---|---------------------|---------------------------------------------------------------|

|   |                     |                                                               |
|---|---------------------|---------------------------------------------------------------|
| 2 | instagram.com/_____ | Public profile associated with the college domain/search term |
|---|---------------------|---------------------------------------------------------------|

|   |                     |                                                               |
|---|---------------------|---------------------------------------------------------------|
| 3 | instagram.com/_____ | Public profile associated with the college domain/search term |
|---|---------------------|---------------------------------------------------------------|

## Search variations

If the first search gives few results, try:

site:instagram.com "college-domain.ac.in"

site:instagram.com "College Name"

site:instagram.com "College Name" students

**Important:** Only record information that is already publicly visible. Don't attempt to obtain private account information.

---

## Task 3: WHOIS Lookup of Zomato

### Command / Tool

You can use:

whois zomato.com

or an online WHOIS service such as WHOIS.com.

### Findings

| Information | Result |
|-------------|--------|
|-------------|--------|

| Information        | Result                |
|--------------------|-----------------------|
| Domain             | zomato.com            |
| Registration date  | 24 February 2006      |
| Registrar          | 101domain GRS Limited |
| Registrant country | India                 |
| Name servers       | AWS DNS servers       |
| Expiry date        | 24 February 2033      |

WHOIS.com reports that zomato.com was registered on **24 February 2006** and is managed by **101domain GRS Limited**.

#### Organization

Current public certificate information identifies **Eternal Limited** in India on certificates covering \*.zomato.com; historical certificates also identify **Zomato Limited**. This reflects corporate/domain information visible in public certificate records and should not be confused with the registrar itself.

#### Short Summary

**Zomato.com** was registered on **24 February 2006**. Public WHOIS information lists India as the registrant country and 101domain GRS Limited as the registrar. Its authoritative DNS infrastructure uses Amazon Route 53 name servers.

---

### Task 4: Subdomain Enumeration of Myntra

#### Tool used

A free public subdomain-finder/Certificate Transparency source was used.

#### Domain

myntra.com

#### Subdomains found

##### No. Subdomain

- 1 www.myntra.com
- 2 api.myntra.com
- 3 developer.myntra.com

## No. Subdomain

- 4 jobs.myntra.com
- 5 accounts.myntra.com
- 6 blog.myntra.com
- 7 careers.myntra.com
- 8 secure.myntra.com
- 9 cdn.myntra.com
- 10 tech.myntra.com

A public subdomain-finder result updated in August 2026 lists these and additional Myntra subdomains, including cdn, secure, jobs, accounts, developer, tech, api, and blog.

## Three required examples

For the assignment, you can list:

- 1. www.myntra.com
- 2. api.myntra.com
- 3. developer.myntra.com

## Method using crt.sh

Certificate Transparency can also reveal publicly logged subdomains. A typical query is:

<https://crt.sh/?q=%.myntra.com>

The % wildcard searches for certificates containing subdomains. CT results can contain historical or expired hostnames, so they should not automatically be treated as currently active systems.

---

## Task 5: Footprinting Demonstration

### Method Chosen: DNS Lookup

For this task, I chose **DNS lookup** because it is simple and demonstrates how publicly available DNS information can be collected.

### Target

www.flipkart.com

### Step 1 – Open Command Prompt

On Windows:

Windows + R → type cmd → Enter

### Step 2 – Run the DNS command

```
nslookup www.flipkart.com
```

### Step 3 – Record the result

Example finding:

Name: www.flipkart.com

Address: 163.53.76.86

Additional DNS information includes UltraDNS name servers and MX records associated with Mimecast.

### Step 4 – Explain the finding

The nslookup command asks the DNS system to translate a domain name into network information such as an IP address. This is an example of **passive reconnaissance/footprinting**, because the information is publicly available and no attempt is made to log in to or exploit Flipkart's systems.

### Screenshot to submit

Take a screenshot showing:

```
C:\Users\YourName>nslookup www.flipkart.com
```

and the resulting IP/DNS information.

### Suggested screenshot caption:

*“DNS footprinting of www.flipkart.com using the nslookup command.”*

---

## Final Submission Summary

### Task Completed Work

- 1 DNS lookup of www.flipkart.com → 163.53.76.86 + NS/MX/SOA information
- 2 Google dorking method provided; requires your actual college domain for genuine first 3 results
- 3 WHOIS research on zomato.com → registered 24 Feb 2006, India, 101domain
- 4 Myntra subdomain enumeration → www, api, developer, jobs, accounts, etc.
- 5 DNS footprinting process using nslookup with screenshot instructions

## Google Advanced Search Operators – Complete Assignment

### Task 1: Find PDF files related to “Java interview questions” on GeeksforGeeks

#### Search Query 1

site:geeksforgeeks.org filetype:pdf "Java interview questions"

#### Search Query 2

site:geeksforgeeks.org filetype:pdf "Java" "interview questions"

#### Search Query 3

site:geeksforgeeks.org filetype:pdf Java interview preparation

#### Result

A relevant GeeksforGeeks resource found through the search is **“Java Interview Questions and Answers.”** It contains more than 200 Core Java interview questions covering topics such as Java fundamentals and interview preparation.

#### Search operators used:

- site: → restricts results to GeeksforGeeks
- filetype:pdf → searches specifically for PDF files
- " " → searches for the exact phrase

---

### Task 2: Instagram Bug Bounty Reports from HackerOne

#### Google Search Query

site:hackerone.com "Instagram" "bug bounty" after:2023-01-01 before:2024-01-01

Another useful query:

site:hackerone.com "Instagram" "vulnerability" after:2023-01-01 before:2024-01-01

A third variation:

site:hackerone.com/hackactivity Instagram after:2023-01-01 before:2024-01-01

#### Explanation

The site:hackerone.com operator restricts the search to HackerOne, while after: and before: restrict the date range to 2023.

HackerOne's own 2023 material confirms that its platform publicly discusses vulnerability reports and bug-bounty activity. Its 2023 Hacker-Powered Security Report was based on HackerOne's vulnerability database and data collected through September 2023.

**Note:** I couldn't verify three specific public Instagram report pages from the indexed search results, so I would **not recommend inventing three report titles** for your submission. You can run the above queries directly in Google and paste the first three actual results.

---

### Task 3: Find Flipkart Coupon Pages

#### Google Dork

site:flipkart.com inurl:coupon -expired

#### Other useful queries

site:flipkart.com inurl:coupon

site:flipkart.com "coupon" -expired

#### Explanation

Here:

- site:flipkart.com → searches only Flipkart's website.
- inurl:coupon → finds pages where **coupon** occurs in the URL.
- -expired → excludes pages containing the word **expired**.

#### Finding

The search can also surface Flipkart product pages containing currently displayed coupon/offer information. For example, indexed Flipkart product pages show “Unlock [brand] coupon” offers.

**Conclusion:** Google operators can narrow Flipkart's large website to pages containing coupon-related information while excluding pages containing “expired.”

---

### Task 4: Google Drive IPL Search

The assignment asks for public Google Drive folders containing IPL match highlights. Because match highlights are copyrighted content, I wouldn't recommend using Google dorks to locate unauthorized copies.

For the **search-operator learning objective**, you can demonstrate the technique with legitimately shared/public cricket material instead.

#### Query 1

site:drive.google.com/drive/folders "IPL" "highlights"

## Query 2

site:drive.google.com/drive/folders "IPL" cricket

### Operators used

- site:drive.google.com → restricts results to Google Drive.
- /drive/folders → targets publicly indexed Drive folders.
- "IPL" → searches the exact term.
- "highlights" → searches for folders containing the specified term.

### Assignment explanation

I used Google advanced search operators to restrict results to publicly indexed Google Drive folders. The queries combined the site: operator with /drive/folders and IPL-related keywords. Search results should be checked to ensure that any material is legitimately shared and not an unauthorized copy of copyrighted broadcasts.

---

## Task 5: Generate Google Dorks for Publicly Published Fintech Email Addresses

For this task, use searches that find **officially published business/security contact addresses**, rather than trying to discover private or leaked personal email addresses.

### Query 1 – Paytm

site:paytm.com ("@paytm.com") ("contact" OR "support" OR "security")

### Query 2 – PhonePe

site:phonepe.com ("@phonepe.com") ("contact" OR "support" OR "security")

### Query 3 – Indian fintech security contacts

site:\*.in ("@paytm.com" OR "@phonepe.com") ("security" OR "contact")

### Test Query

I would test the **Paytm** query first:

site:paytm.com "@paytm.com" security

### Expected result

The purpose of the search is to locate **publicly documented organizational contact information**, such as security-reporting or customer-support addresses published on official websites. It should not be used to collect private people's email addresses.

### What I learned

Google advanced operators can significantly narrow search results. The site: operator limits results to a particular domain, quotation marks search for an exact string, and OR allows multiple alternatives. These techniques are useful for cybersecurity reconnaissance when used only with information that an organization has intentionally made public.

---

### Important Google Operators Used

| Operator  | Purpose                            | Example                    |
|-----------|------------------------------------|----------------------------|
| site:     | Search a particular website/domain | site:geeksforgeeks.org     |
| filetype: | Search for a specific file type    | filetype:pdf               |
| inurl:    | Search for a word in the URL       | inurl:coupon               |
| " "       | Search an exact phrase             | "Java interview questions" |
| -         | Exclude a word                     | -expired                   |
| after:    | Search after a date                | after:2023-01-01           |
| before:   | Search before a date               | before:2024-01-01          |
| OR        | Search for either term             | security OR contact        |

### Final conclusion

Google Advanced Search Operators are useful for **open-source intelligence (OSINT)** and cybersecurity reconnaissance. Operators such as site:, filetype:, inurl:, quotation marks, date filters, and exclusion operators allow researchers to narrow publicly available information efficiently. The same techniques should be used responsibly and should not be used to access private information, bypass access controls, or obtain unauthorized copyrighted material.

## **Nmap – Network Scanning Assignment**

### **Task 1: Scan Your Local Wi-Fi Network**

#### **Step 1: Install Nmap**

Download and install **Nmap** from the official Nmap website.

After installation, open **Command Prompt** as Administrator.

#### **Step 2: Find your local IP address**

Run:

```
ipconfig
```

Look for:

IPv4 Address

Default Gateway

For example:

IPv4 Address : 192.168.1.10

Default Gateway : 192.168.1.1

Your network would then generally be:

192.168.1.0/24

#### **Step 3: Scan the local network**

Run:

```
nmap -sn 192.168.1.0/24
```

Replace 192.168.1.0/24 with your actual network.

-sn performs host discovery without doing a port scan.

#### **Example Result**

Your result may look similar to:

Nmap scan report for 192.168.1.1

Host is up

MAC Address: XX:XX:XX:XX:XX:XX (TP-Link)

Nmap scan report for 192.168.1.5

Host is up

MAC Address: XX:XX:XX:XX:XX:XX (Samsung)

Nmap scan report for 192.168.1.10

Host is up

MAC Address: XX:XX:XX:XX:XX:XX (Dell)

**Assignment Table**

**IP Address    Device Name/Type    MAC Address**

|              |              |                   |
|--------------|--------------|-------------------|
| 192.168.1.1  | Wi-Fi Router | XX:XX:XX:XX:XX:XX |
| 192.168.1.5  | Smartphone   | XX:XX:XX:XX:XX:XX |
| 192.168.1.10 | Laptop/PC    | XX:XX:XX:XX:XX:XX |

**Important:** The IP/MAC values above are examples. Replace them with the actual values from your own scan rather than submitting invented device information.

---

**Task 2: ARP Table Using arp -a**

Open Command Prompt and enter:

arp -a

You may see something similar to:

Interface: 192.168.1.10

| Internet Address | Physical Address  | Type    |
|------------------|-------------------|---------|
| 192.168.1.1      | 34-xx-xx-xx-xx-xx | dynamic |
| 192.168.1.5      | 78-xx-xx-xx-xx-xx | dynamic |
| 192.168.1.8      | a4-xx-xx-xx-xx-xx | dynamic |

**Two Devices**

**IP Address    MAC Address    Type**

192.168.1.1 34-XX-XX-XX-XX-XX Dynamic

| IP Address  | MAC Address       | Type    |
|-------------|-------------------|---------|
| 192.168.1.5 | 78-XX-XX-XX-XX-XX | Dynamic |

### Explanation

The **ARP (Address Resolution Protocol) table** maps local IP addresses to MAC addresses. The `arp -a` command displays entries that your computer currently knows about.

Again, use the **actual IP and MAC addresses shown on your computer** for the final submission.

### Task 3: Scan Your Own Computer

To scan your own computer, first find your IPv4 address using:

```
ipconfig
```

Suppose your address is:

```
192.168.1.10
```

Run:

```
nmap 192.168.1.10
```

For service/version detection:

```
nmap -sV 192.168.1.10
```

Nmap's `-sV` option attempts to determine the service and version running on discovered open ports.

### Example Result

```
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
3389/tcp   closed ms-wbt-server
```

### Summary Table

#### Port Status Common Service Purpose

|     |      |             |                    |
|-----|------|-------------|--------------------|
| 135 | Open | MSRPC       | Microsoft RPC      |
| 139 | Open | NetBIOS-SSN | Windows networking |

## Port Status Common Service Purpose

445 Open Microsoft-DS/SMB Windows file/network sharing

3389 Closed RDP Remote Desktop

**Your actual results may be different** depending on Windows settings, firewall configuration, and running applications.

---

### Task 4: Zomato-Style Scenario – scanme.nmap.org

For this task, the assignment specifically provides **scanme.nmap.org**, which is Nmap's publicly provided scanning target.

Run:

```
nmap scanme.nmap.org
```

Nmap's official documentation uses scanme.nmap.org in its examples and documents open ports including SSH and HTTP.

### Example Findings

| Port           | State  | Service    | Possible Purpose                |
|----------------|--------|------------|---------------------------------|
| <b>22/tcp</b>  | Open   | SSH        | Secure remote administration    |
| <b>53/tcp</b>  | Open   | DNS        | Domain-name resolution          |
| <b>80/tcp</b>  | Open   | HTTP       | Web server                      |
| <b>25/tcp</b>  | Closed | SMTP       | Email transfer                  |
| <b>113/tcp</b> | Closed | Ident/Auth | Authentication/identity service |

Nmap's documented example shows ports 22, 53, and 80 as open and identifies them as SSH, DNS, and HTTP respectively.

### Explanation

#### Port 22 – SSH:

Used for secure remote login and administration.

#### Port 53 – DNS:

Used for DNS services that translate domain names into IP addresses.

#### Port 80 – HTTP:

Used by web servers to provide HTTP websites.

Port numbers are commonly associated with services, but the actual service should be verified rather than assumed solely from the port number. Nmap's service-detection feature can provide additional information.

---

### Task 5: Show Only Open Ports and Services

The assignment asks you to use `--open` and `-sV`.

#### Command

```
nmap --open -sV scanme.nmap.org
```

#### Example Output

```
PORT      STATE SERVICE VERSION
```

```
22/tcp    open  ssh      OpenSSH
```

```
80/tcp    open  http     Apache httpd
```

The `--open` option tells Nmap to show only ports that are open or potentially open, rather than listing closed ports. `-sV` enables service/version detection.

#### Clean Results Table

| Port | State | Service | Version/Description |
|------|-------|---------|---------------------|
|------|-------|---------|---------------------|

|        |      |     |              |
|--------|------|-----|--------------|
| 22/tcp | Open | SSH | Secure Shell |
|--------|------|-----|--------------|

|        |      |      |            |
|--------|------|------|------------|
| 80/tcp | Open | HTTP | Web server |
|--------|------|------|------------|

#### Final Command to Submit

```
nmap --open -sV scanme.nmap.org
```

---

### Final Assignment Summary

| Task | Command / Method                             | Purpose                                          |
|------|----------------------------------------------|--------------------------------------------------|
| 1    | <code>nmap -sn 192.168.1.0/24</code>         | Find devices on your local Wi-Fi                 |
| 2    | <code>arp -a</code>                          | Display IP-to-MAC mappings                       |
| 3    | <code>nmap -sV &lt;your-IP&gt;</code>        | Find open ports and services on your own PC      |
| 4    | <code>nmap scanme.nmap.org</code>            | Practice scanning an authorized Nmap test server |
| 5    | <code>nmap --open -sV scanme.nmap.org</code> | Display only open ports and identify services    |

### Conclusion

Nmap is a network-scanning tool used to discover hosts, identify open ports, and determine services running on networked systems. The `-sV` option helps identify service versions, while `--open` makes the output easier to read by filtering out ports that are not open. Nmap's documentation demonstrates these techniques using [scanme.nmap.org](https://scanme.nmap.org), an example target provided for scanning practice.

**For Tasks 1–3, use your own actual scan output in the tables. Tasks 4–5 can be completed using the documented [scanme.nmap.org](https://scanme.nmap.org) example.**

## Check Live System, Open Ports & Services

### Task 1: Use netstat to Check Open Ports

#### Windows

Open **Command Prompt as Administrator** and run:

```
netstat -ano
```

This displays active connections and listening ports.

For only listening ports:

```
netstat -ano | findstr LISTENING
```

#### Example Output

| Proto | Local Address  | Foreign Address | State     | PID  |
|-------|----------------|-----------------|-----------|------|
| TCP   | 0.0.0.0:135    | 0.0.0.0:0       | LISTENING | 1120 |
| TCP   | 0.0.0.0:445    | 0.0.0.0:0       | LISTENING | 4    |
| TCP   | 0.0.0.0:3389   | 0.0.0.0:0       | LISTENING | 980  |
| TCP   | 127.0.0.1:3306 | 0.0.0.0:0       | LISTENING | 4520 |

#### What the columns mean

- **Proto:** Network protocol, such as TCP or UDP
- **Local Address:** Your computer's IP address and port
- **Foreign Address:** Remote IP address and port
- **State:** Connection status
- **PID:** Process ID of the application using the port

#### Assignment Answer

| Port | State | PID | Typical Service |
|------|-------|-----|-----------------|
|------|-------|-----|-----------------|

|     |           |      |               |
|-----|-----------|------|---------------|
| 135 | LISTENING | 1120 | Microsoft RPC |
|-----|-----------|------|---------------|

|     |           |   |                          |
|-----|-----------|---|--------------------------|
| 445 | LISTENING | 4 | Windows SMB/File Sharing |
|-----|-----------|---|--------------------------|

|      |           |     |                |
|------|-----------|-----|----------------|
| 3389 | LISTENING | 980 | Remote Desktop |
|------|-----------|-----|----------------|

|      |           |      |       |
|------|-----------|------|-------|
| 3306 | LISTENING | 4520 | MySQL |
|------|-----------|------|-------|

**Important:** These are example results. Your actual netstat output will depend on the applications running on your computer. Take a screenshot of your own command output for submission.

---

## Task 2: Find Applications Using Ports 80 and 443

Run:

```
netstat -ano | findstr ":80"
```

and:

```
netstat -ano | findstr ":443"
```

The last number in each line is the **PID**.

For example:

```
TCP 0.0.0.0:443 0.0.0.0:0 LISTENING 4520
```

Here, the PID is **4520**.

Now identify the process:

```
tasklist /FI "PID eq 4520"
```

### Example

| Image Name | PID |
|------------|-----|
|------------|-----|

|           |      |
|-----------|------|
| httpd.exe | 4520 |
|-----------|------|

### Assignment Table

| Port | PID | Process/Application |
|------|-----|---------------------|
|------|-----|---------------------|

|    |      |           |
|----|------|-----------|
| 80 | 4520 | httpd.exe |
|----|------|-----------|

|     |      |           |
|-----|------|-----------|
| 443 | 4520 | httpd.exe |
|-----|------|-----------|

**Note:** If nothing appears, it simply means no application is currently listening on that port on your machine.

---

## Task 3: Scan Your Own System Using Nmap

First find your local IP:

```
ipconfig
```

Suppose your IPv4 address is:

```
192.168.1.10
```

Run:

```
nmap -sV 192.168.1.10
```

The `-sV` option attempts to identify the services and versions running on open ports.

### Example Output

| PORT    | STATE | SERVICE      | VERSION                       |
|---------|-------|--------------|-------------------------------|
| 135/tcp | open  | msrpc        | Microsoft Windows RPC         |
| 139/tcp | open  | netbios-ssn  | Microsoft Windows netbios-ssn |
| 445/tcp | open  | microsoft-ds | Windows SMB                   |

### Assignment Table

#### Port Service Example Description

|     |         |                                 |
|-----|---------|---------------------------------|
| 135 | MSRPC   | Microsoft Remote Procedure Call |
| 139 | NetBIOS | Windows network communication   |
| 445 | SMB     | Windows file/printer sharing    |

### Alternative: Zenmap

If you use **Zenmap**, enter your own IP address as the target and select an appropriate scan profile. Do not scan devices or networks you don't own or have permission to test.

---

## Task 4: Check Ports Used by an Application

### Example Application: Spotify

Start **Spotify** and then run:

```
netstat -ano
```

You can also filter for Spotify-related connections if you know its PID.

First find the process:

```
tasklist | findstr /I "Spotify"
```

Then use its PID:

```
netstat -ano | findstr "PID"
```

### Example Table

| Port | Typical Use |
|------|-------------|
|------|-------------|

| Port | Typical Use                                                         |
|------|---------------------------------------------------------------------|
| 443  | HTTPS/TLS encrypted communication with Internet services            |
| 80   | HTTP communication, although modern applications commonly use HTTPS |
| 53   | DNS name resolution                                                 |

Dynamic/high ports Temporary client-side connections to remote servers

**Important:** Spotify does not necessarily use one fixed set of local listening ports. The actual ports visible on your computer can change depending on the application version, operating system, and network connections.

---

## Commands to Submit

### Task 1

```
netstat -ano
```

or:

```
netstat -ano | findstr LISTENING
```

### Task 2

```
netstat -ano | findstr ":80"
```

```
netstat -ano | findstr ":443"
```

```
tasklist /FI "PID eq <PID>"
```

### Task 3

```
nmap -sV <YOUR-IP>
```

### Task 4

```
tasklist | findstr /I "Spotify"
```

```
netstat -ano
```

---

## Conclusion

netstat is useful for viewing active network connections and listening ports on a computer. The PID shown by netstat -ano can be matched with Windows processes using tasklist. Nmap can then be used on your own system to identify open ports and the services associated with them. These tools help administrators understand which network services are active and identify unnecessary exposed services.

**For Tasks 1–4, replace the example IPs, PIDs, processes, and ports with the results from your own computer before submitting the assignment.**

## Vulnerability Scanning – Complete Assignment

### Task 1: Install and Run OpenVAS / Nessus

For this assignment, I recommend using **Greenbone Community Edition (OpenVAS)**. Greenbone's current documentation identifies Greenbone Community Edition as the open-source vulnerability-management stack that includes OpenVAS.

#### Kali Linux installation

Open Terminal and run:

```
sudo apt update
```

```
sudo apt install gvm -y
```

Greenbone's Kali documentation provides gvm as the package for installing Greenbone Community Edition/OpenVAS.

Then run the setup:

```
sudo gvm-setup
```

Start the services:

```
sudo gvm-start
```

After installation, open the Greenbone Security Assistant (GSA) interface in your browser.

#### Target

For a safe assignment, scan **your own computer**:

```
127.0.0.1
```

or your own local virtual machine, for example:

```
192.168.1.20
```

#### Example findings

A vulnerability scanner may report items such as:

| Finding                  | Description                                    | Risk       |
|--------------------------|------------------------------------------------|------------|
| Outdated software        | A service is running an old version            | Medium     |
| Missing security update  | Operating-system update is unavailable         | Medium     |
| Weak configuration       | A service is configured insecurely             | Medium     |
| Unnecessary open service | A service is accessible when it isn't required | Low/Medium |

**Important:** Don't copy these as your actual scan results. Run the scan and use the findings generated by your own system.

---

**Task 2: Scan Your Wi-Fi Router**

First find your router's IP address.

On Windows:

ipconfig

Look for:

Default Gateway

For example:

Default Gateway . . . . . : 192.168.1.1

Then scan **your own router**:

nmap -v 192.168.1.1

Nmap's -p option can also be used when you want to specify particular ports; by default Nmap scans its commonly used port set.

**Example output**

```
PORT      STATE  SERVICE
53/tcp    open   domain
80/tcp    open   http
443/tcp   open   https
```

**Assignment table**

**Port State Common Service Purpose**

|     |      |       |                                   |
|-----|------|-------|-----------------------------------|
| 53  | Open | DNS   | Resolves domain names             |
| 80  | Open | HTTP  | Web-based router interface        |
| 443 | Open | HTTPS | Secure web-based router interface |

**Use your actual router IP and actual Nmap results in the final submission.**

---

**Task 3: Analyze the Vulnerability Scanner Report**

After completing the OpenVAS/Greenbone scan, open the generated report.

Look for findings with different severity levels.

**Example analysis format**

| Vulnerability/Finding Severity Description |        |                                                                        | Risk                                                        |
|--------------------------------------------|--------|------------------------------------------------------------------------|-------------------------------------------------------------|
| Outdated software                          | High   | A software package is using an old version with known security issues. | Attackers could potentially exploit the outdated component. |
| Weak TLS configuration                     | Medium | The system may support older or weaker cryptographic settings.         | Could reduce communication security.                        |
| Missing security update                    | Medium | A recommended security update has not been installed.                  | Known vulnerabilities may remain unpatched.                 |

**Example one-line risk descriptions**

**High:**

An attacker could potentially exploit this weakness to gain unauthorized access or compromise the system.

**Medium:**

The vulnerability could provide an attacker with additional opportunities to compromise the system, especially when combined with another weakness.

**Low:**

The issue has limited direct impact but should still be corrected as part of good security practice.

**Conclusion**

The scan report should be prioritized according to severity. High-risk findings should generally receive attention before lower-risk configuration issues, and software should be updated where appropriate.

---

**Task 4: Real Vulnerability Example – Paytm-Related Software**

For this task, a useful documented example is **CVE-2025-22640**, which affected the WordPress plugin **Paytm Payment Donation**.

**Vulnerability**

**CVE:** CVE-2025-22640

**Type:** Stored Cross-Site Scripting (XSS)

The National Vulnerability Database records that the affected Paytm Payment Donation plugin was vulnerable through version **2.3.3**. The vulnerability involved improper neutralization of input when generating web pages.

## What could happen?

Stored XSS occurs when malicious input is stored by an application and later displayed to another user without being properly sanitized.

In general, this type of vulnerability can allow attacker-controlled script content to execute in a victim's browser under certain conditions.

## How could a scanner detect it?

A vulnerability scanner can:

1. Identify the application/plugin and its version.
2. Compare the detected version against vulnerability databases.
3. Match the software/version combination to a known CVE.
4. Report the CVE and affected version range.

The important point is that vulnerability scanning can identify **known vulnerable software versions** without requiring the student to exploit the vulnerability.

## Patch/Prevention

The appropriate defense is to update the affected software to a version that contains the security fix and keep third-party components regularly updated.

Paytm also operates a vulnerability disclosure program and explicitly lists XSS among the vulnerability categories it accepts.

**Note:** This CVE concerns a WordPress plugin called *Paytm Payment Donation*; it should not be described as a vulnerability in the core Paytm consumer app itself.

---

## Task 5: Bash Script to Scan 3 IP Addresses

The following script demonstrates how to run Nmap against **three systems you own or are authorized to test** and save each result to a separate file.

### Bash Script

```
#!/bin/bash
```

```
# IP addresses of authorized test systems
```

```
IPS=("192.168.1.10" "192.168.1.20" "192.168.1.30")
```

```
# Create output directory
```

```
mkdir -p nmap_results
```

```
# Scan each IP
```

```
for IP in "${IPS[@]}"
```

```
do
```

```
    echo "Scanning $IP..."
```

```
    nmap -sV "$IP" > "nmap_results/${IP}.txt"
```

```
    echo "Result saved to nmap_results/${IP}.txt"
```

```
done
```

```
echo "All scans completed."
```

### **How it works**

The script:

1. Creates a list containing three IP addresses.
2. Uses a for loop to process each address.
3. Runs:

```
nmap -sV "$IP"
```

4. Saves each result into a separate .txt file.
5. Creates the nmap\_results folder automatically.

### **Example output files**

```
nmap_results/
```

```
├─ 192.168.1.10.txt
```

```
├─ 192.168.1.20.txt
```

```
└─ 192.168.1.30.txt
```

### **Example terminal output**

```
Scanning 192.168.1.10...
```

Result saved to nmap\_results/192.168.1.10.txt

Scanning 192.168.1.20...

Result saved to nmap\_results/192.168.1.20.txt

Scanning 192.168.1.30...

Result saved to nmap\_results/192.168.1.30.txt

All scans completed.

Nmap's -sV option is used for service/version detection. Nmap also allows specific port ranges with -p; for example, -p 80,443 scans only HTTP/HTTPS ports.

---

## Final Submission Summary

### Task Work Completed

- 1 Installed/used Greenbone Community Edition (OpenVAS) and scanned an authorized local system
- 2 Used nmap -v <router-IP> to identify open router ports
- 3 Analyzed vulnerability findings by severity and risk
- 4 Researched CVE-2025-22640, a stored-XSS vulnerability in the Paytm Payment Donation WordPress plugin
- 5 Created a Bash script that scans 3 authorized IPs and saves each result separately

### Overall Conclusion

Vulnerability scanning combines **port/service discovery** with databases of known vulnerabilities to identify security weaknesses. Tools such as Nmap can identify exposed services, while Greenbone/OpenVAS can perform broader vulnerability assessments. The results should be used to patch outdated software, remove unnecessary services, and improve system configuration. Greenbone's scanner uses continuously updated vulnerability tests, making its feed an important part of the assessment process.

**For Tasks 1–3, remember to attach screenshots of your own OpenVAS/Nmap results; the example findings above should not be presented as results from your computer.**

**Assignment: Describing VAPT and VAPT Reports Writing**

**Task 1: What is VAPT?**

**VAPT** stands for **Vulnerability Assessment and Penetration Testing**. It is a cybersecurity process used to identify security weaknesses in systems, applications, networks, and websites. Vulnerability Assessment mainly focuses on finding and identifying vulnerabilities, while Penetration Testing goes a step further by safely testing whether those vulnerabilities can actually be exploited.

**Two Differences Between Vulnerability Assessment and Penetration Testing**

| Vulnerability Assessment                                 | Penetration Testing                                                           |
|----------------------------------------------------------|-------------------------------------------------------------------------------|
| Identifies and reports security vulnerabilities.         | Attempts to safely exploit identified vulnerabilities to verify their impact. |
| Usually uses automated vulnerability scanners and tools. | Often involves manual testing along with security tools and techniques.       |

**Example:**

A vulnerability scanner may report that a website has an outdated software component. A penetration tester may then test the identified weakness in an authorized environment to determine whether it could actually allow unauthorized access.

---

**Task 2: VAPT for a Food Delivery App**

Imagine that we are performing VAPT on a food delivery application similar to **Zomato**.

**Three Common Vulnerabilities to Check**

**1. SQL Injection (SQLi)**

SQL Injection occurs when an application does not properly validate user input before using it in database queries. An attacker may manipulate input fields to access or modify unauthorized database information.

**Example areas to check:**

- Login forms
- Search fields
- Restaurant IDs
- Order IDs
- API parameters

**Risk:** High

---

## 2. Cross-Site Scripting (XSS)

XSS occurs when an application allows malicious scripts to be inserted into webpages or user-generated content. If successful, it could affect other users who view the infected content.

### Example areas to check:

- Restaurant reviews
- User comments
- Profile information
- Search fields

**Risk:** Medium to High

---

## 3. Broken Access Control / IDOR

Broken access control occurs when a user can access information or perform actions that should belong only to another user or administrator.

### Example:

A normal customer should only be able to view their own orders. If changing an order identifier allows them to access another customer's order information, this indicates an access-control weakness.

**Risk:** High

### Other areas that could be checked

- Authentication and login security
  - Password reset functionality
  - Session management
  - API security
  - Sensitive data exposure
  - Insecure file upload
  - Security misconfiguration
  - Rate limiting
- 

## Task 3: Sample VAPT Report for a Fictional E-Wallet App

### VAPT Report

**Application:** PaySecure – Fictional E-Wallet Application  
**Assessment Type:** Vulnerability Assessment and Penetration Testing  
**Target:** Web Application and APIs  
**Testing Environment:** Authorized Test Environment

---

## 1. Executive Summary

A Vulnerability Assessment and Penetration Testing exercise was performed on the fictional **PaySecure e-wallet application** to identify potential security weaknesses in its web application and APIs.

The assessment focused on authentication, authorization, input validation, session management, API security, and protection of sensitive information.

Several security issues were identified during the assessment. The findings should be prioritized according to their risk level and fixed before the application is deployed to production.

---

## 2. Methodology

The assessment followed these general phases:

1. **Information Gathering** – Identifying application components, APIs, and available functionality.
2. **Vulnerability Assessment** – Checking the application for common security weaknesses.
3. **Manual Security Testing** – Validating important findings manually in the authorized test environment.
4. **Risk Assessment** – Assigning risk levels based on potential impact and likelihood.
5. **Reporting** – Documenting vulnerabilities, their impact, and recommended remediation.

### Tools that may be used

- Nmap
  - OWASP ZAP
  - Burp Suite
  - OpenVAS/Greenbone
  - Browser Developer Tools
- 

## 3. Vulnerabilities Found

| ID | Vulnerability | Risk Level | Description |
|----|---------------|------------|-------------|
|----|---------------|------------|-------------|

|         |                            |        |                                                                                                             |
|---------|----------------------------|--------|-------------------------------------------------------------------------------------------------------------|
| VAPT-01 | Broken Access Control      | High   | A user may potentially access resources belonging to another user if authorization checks are insufficient. |
| VAPT-02 | Cross-Site Scripting (XSS) | Medium | Improper input/output handling may allow malicious scripts to be stored or displayed in the application.    |
| VAPT-03 | Weak Password Policy       | Medium | The application may allow users to create passwords that are too weak and easier to guess.                  |
| VAPT-04 | Missing Security Headers   | Low    | Important HTTP security headers may be missing, increasing exposure to certain web-based attacks.           |

---

## 4. Risk Ratings

### High Risk

Vulnerabilities that could potentially result in unauthorized access to sensitive user information or important application functionality.

### Medium Risk

Vulnerabilities that could affect users or application security but generally require additional conditions or interaction.

### Low Risk

Issues that have a limited direct security impact but should still be corrected as part of security hardening.

---

## 5. Recommendations

- Implement proper authorization checks on every sensitive API and application function.
- Validate and sanitize user input.
- Apply appropriate output encoding to prevent XSS.
- Enforce a strong password policy.
- Implement multi-factor authentication where appropriate.
- Use secure session management and session expiration.
- Add appropriate HTTP security headers.
- Keep application dependencies and server software updated.
- Perform regular vulnerability assessments and penetration tests.
- Log and monitor suspicious authentication and application activity.

---

## 6. Conclusion

The VAPT assessment helps identify weaknesses before they can be abused in a real-world attack. The identified vulnerabilities should be prioritized according to their risk levels and remediated by the development and security teams. After fixes are implemented, a retest should be performed to verify that the vulnerabilities have been properly resolved.

---

### Task 4: VAPT Report Entry – Plain-Text Passwords

#### Vulnerability: Passwords Stored in Plain Text

##### Description:

During the VAPT assessment of the movie ticket booking application, it was discovered that user passwords are stored in **plain text in the database**. This means that anyone who gains unauthorized access to the database could directly read the users' passwords.

##### Risk Level: Critical

##### Impact:

An attacker who obtains the database could access user passwords and potentially use them to log in to user accounts. If users reuse the same passwords on other services, those accounts could also be at risk.

##### Recommendation:

Passwords should never be stored as plain text. The application should use a strong, modern password-hashing algorithm such as **Argon2id, bcrypt, or scrypt**, with appropriate password-hashing parameters. Existing plain-text passwords should be migrated through a secure password-reset process, and database access should be strictly restricted.

##### Retesting:

After remediation, the database should be reviewed to confirm that passwords are no longer stored in readable form and that authentication continues to work correctly.

## Assignment: Burp Suite and OWASP VAPT Tools

### Task 1: Install Burp Suite Community Edition

#### Objective

To install and launch **Burp Suite Community Edition** and understand its main dashboard.

#### Steps

1. Download **Burp Suite Community Edition** from the official PortSwigger website.
2. Install it on the computer.
3. Launch Burp Suite.
4. Select **Temporary project** if prompted.
5. Select the default configuration.
6. Click **Start Burp**.
7. The Burp Suite dashboard will open.
8. Take a screenshot of the main dashboard and attach it to the assignment.

#### Screenshot to Submit

**Screenshot 1:** Burp Suite Community Edition main dashboard after launching.

#### Observation:

Burp Suite provides several security-testing tools, including Proxy, Repeater, Intruder and other components. The Proxy tool can intercept and inspect HTTP/HTTPS traffic between a browser and a web application.

---

### Task 2: Intercept HTTP Requests Using Burp Proxy

#### Objective

To use Burp Proxy to intercept HTTP requests while visiting a deliberately vulnerable/demo web application.

#### Steps

1. Open Burp Suite.
2. Go to **Proxy → Intercept**.
3. Turn **Intercept** on.
4. Use **Burp's built-in browser** by clicking **Open Browser**. This browser is already configured to work with Burp Proxy.
5. Visit:

http://testphp.vulnweb.com/

6. Navigate to the login page or another page containing a form.
7. Submit the form with test information.
8. Burp Proxy will intercept the HTTP request.
9. Observe the request in the **Proxy → Intercept** window.
10. Take a screenshot.
11. Click **Forward** to send the request to the server.

Burp's official documentation confirms that intercepted requests can be inspected before being forwarded to the target.

### Example Intercepted Request Headers

The exact headers will depend on your browser and the request you intercept. A typical request may contain:

GET /login.php HTTP/1.1

Host: testphp.vulnweb.com

User-Agent: Mozilla/5.0

Accept: text/html,application/xhtml+xml

Accept-Language: en-US,en;q=0.9

Connection: keep-alive

Cookie: <session-cookie>

### Header Explanation

| Header          | Purpose                                                   |
|-----------------|-----------------------------------------------------------|
| Host            | Specifies the destination website.                        |
| User-Agent      | Identifies the browser/client making the request.         |
| Accept          | Indicates the content types accepted by the browser.      |
| Accept-Language | Specifies preferred languages.                            |
| Connection      | Controls the HTTP connection behavior.                    |
| Cookie          | Contains session-related information sent by the browser. |

**Important:** The exact values in your screenshot will be different. Copy the headers from your actual intercepted request rather than submitting the example values.

**Screenshot to Submit**

**Screenshot 2:** Burp Proxy → Intercept showing the captured HTTP request and headers.

---

**Task 3: Three Open-Source VAPT Tools Listed by OWASP**

OWASP maintains a large collection of open-source security projects and tools.

**1. OWASP ZAP**

**Purpose:**

OWASP ZAP (Zed Attack Proxy) is an open-source web application security testing tool used to find vulnerabilities through automated and manual testing.

**2. OWASP Amass**

**Purpose:**

OWASP Amass is an open-source framework used for attack-surface mapping, asset discovery, and reconnaissance using OSINT techniques.

**3. OWASP Dependency-Check**

**Purpose:**

OWASP Dependency-Check is a Software Composition Analysis tool that identifies project dependencies and checks them against known publicly disclosed vulnerabilities.

**Summary Table**

| Tool                   | Main Purpose                                                |
|------------------------|-------------------------------------------------------------|
| OWASP ZAP              | Web application vulnerability scanning and security testing |
| OWASP Amass            | Attack-surface mapping and asset discovery                  |
| OWASP Dependency-Check | Finding known vulnerabilities in software dependencies      |

---

**Task 4: Basic Vulnerability Scan Using OWASP ZAP**

**Objective**

To perform a basic vulnerability scan against the intentionally vulnerable training website:

<http://testphp.vulnweb.com/>

The website is specifically used as a vulnerable testing target, so it is appropriate for security-learning exercises.

**Steps Using OWASP ZAP**

1. Download and install **OWASP ZAP**.
2. Open ZAP.
3. Start a new session if prompted.
4. Select the **Automated Scan / Quick Start** option.
5. Enter:

`http://testphp.vulnweb.com/`

6. Start the automated scan.
7. Wait for the spider and scanner to complete.
8. Open the **Alerts** section.
9. Record at least two alerts detected by ZAP.
10. Take a screenshot of the Alerts tab.

## Findings

Your actual ZAP results should be used here because alerts can vary depending on the scanner version, scan configuration, and target response.

For reference, independent scans of this deliberately vulnerable training site have documented issues including **SQL Injection** and **Cross-Site Scripting (XSS)**.

You can use the following format after running your own scan:

| Alert Detected in ZAP      |                | Risk | Description                                                                             |
|----------------------------|----------------|------|-----------------------------------------------------------------------------------------|
| SQL Injection              | High/Critical* |      | Improper handling of input may allow database queries to be manipulated.                |
|                            |                |      |                                                                                         |
| Cross-Site Scripting (XSS) | High/Medium*   |      | Improper input/output handling may allow script content to execute in a user's browser. |

\*Use the **exact risk rating displayed by your ZAP version**.

## Screenshot to Submit

**Screenshot 3:** OWASP ZAP Alerts/scan-results window showing at least two detected alerts.

## Observation

The scan demonstrates how an automated DAST tool can crawl a web application and identify potentially vulnerable input points and security configuration issues.

---

## Task 5: SQL Injection Testing Using Burp Suite

## AI-Generated Step-by-Step Guide

**Target:** <http://testphp.vulnweb.com/>

**Purpose:** Educational testing against an intentionally vulnerable demonstration website only.

### Step 1: Open the Demo Website

Open Burp Suite and launch **Burp's Browser**.

Visit:

<http://testphp.vulnweb.com/>

---

### Step 2: Find a Parameterized Request

Browse the website and look for a URL containing a parameter, for example:

</artists.php?artist=1>

The artist parameter is an example of a user-controlled input.

The test site is intentionally vulnerable, and published security documentation demonstrates SQL-injection testing against this parameter.

---

### Step 3: Intercept the Request

1. Go to **Proxy** → **Intercept**.
2. Turn interception on.
3. Visit the parameterized page.
4. Burp should capture the HTTP request.

Example:

GET /artists.php?artist=1 HTTP/1.1

Host: testphp.vulnweb.com

---

### Step 4: Send the Request to Repeater

Right-click the intercepted request and select:

**Send to Repeater**

Then open the **Repeater** tab.

Repeater allows the request to be reviewed and sent again while changing test input.

---

### **Step 5: Perform a Basic SQL Injection Test**

For a simple educational test, modify the parameter from:

artist=1

to a basic malformed input such as:

artist=1'

Send the request.

Observe whether the response changes or produces a database-related error.

**Do not test this technique against websites that you do not own or have explicit permission to assess.**

---

### **Step 6: Compare the Responses**

Compare:

#### **Normal request**

artist=1

with:

#### **Test request**

artist=1'

Look for differences such as:

- HTTP status code
- Response length
- Database error messages
- Different page content
- Different application behavior

A change in behavior can be an indicator that further authorized testing is required; it is not by itself definitive proof of SQL injection.

---

### **Observation**

During the exercise, I observed that Burp Suite made it possible to capture and modify HTTP requests before forwarding them to the server. The normal request and the modified request could then be compared in Repeater.

The main difference between the AI-generated procedure and the practical test was that the exact request structure, cookies, parameters, and server response depended on the demo application's current behavior.

The intentionally vulnerable test site has publicly documented SQL-injection examples, including the artist parameter, which makes it suitable for this type of controlled learning exercise.

---

## Final Conclusion

This assignment provided practical experience with **Burp Suite, OWASP ZAP, and other open-source security tools**. Burp Suite was used to intercept and inspect HTTP requests, while OWASP ZAP was used for automated web vulnerability scanning. OWASP projects such as ZAP, Amass, and Dependency-Check demonstrate different approaches to application and infrastructure security testing.

The exercises also demonstrated how security testers can identify potential vulnerabilities such as SQL Injection and XSS in a controlled environment. All testing should be performed only against systems that are intentionally provided for testing or for which explicit authorization has been obtained.

## Assignment: Introduction to Virtualization

### Theory

#### What is Virtualization?

**Virtualization** is a technology that allows one physical computer to run multiple virtual computers, called **Virtual Machines (VMs)**. Each VM can have its own operating system, applications, storage, and virtual hardware.

For example, a Windows computer can use VirtualBox to run **Ubuntu Linux** inside a virtual machine without replacing the Windows operating system.

#### Types of Hypervisors

A **hypervisor** is software or firmware that creates and manages virtual machines.

There are two main types:

- **Type 1 Hypervisor – Bare Metal:** Runs directly on the physical computer's hardware.
- **Type 2 Hypervisor – Hosted:** Runs as an application on top of an existing operating system.

#### Benefits of Virtualization

1. **Resource sharing:** Multiple VMs can share the hardware resources of one physical computer.
  2. **Isolation:** Problems inside one VM generally remain isolated from the host and other VMs.
  3. **Cost reduction:** Multiple virtual systems can run on a single physical machine.
  4. **Testing:** Different operating systems and software can be tested without modifying the main OS.
  5. **Snapshots and recovery:** VM snapshots can make it easier to return a VM to an earlier state.
- 

### Task 1: Install VirtualBox or VMware Workstation

#### Objective

Install a virtualization platform on the computer.

#### Software Used

##### Oracle VirtualBox

#### Installation Steps

1. Download Oracle VirtualBox from its official website.
2. Run the VirtualBox installer.
3. Follow the installation wizard.

4. Keep the default installation options unless there is a specific reason to change them.
5. Click **Install**.
6. Wait for the installation to complete.
7. Launch **Oracle VM VirtualBox**.
8. Confirm that the VirtualBox Manager opens successfully.

## Screenshot

Take a screenshot showing:

**VirtualBox Manager successfully installed and opened.**

**Screenshot 1:** *VirtualBox installation completed / VirtualBox Manager window.*

## Observation

VirtualBox was successfully installed and launched. It can be used to create and manage virtual machines on the host computer.

---

## Task 2: Create an Ubuntu Virtual Machine

### Objective

Create a virtual machine configured to run Ubuntu Linux with at least **2 GB RAM and 20 GB storage**.

### Requirements

| Resource                | Configuration    |
|-------------------------|------------------|
| Guest OS                | Ubuntu Linux     |
| RAM                     | 2 GB or more     |
| Storage                 | 20 GB or more    |
| Virtualization Software | VirtualBox       |
| ISO                     | Ubuntu Linux ISO |

### Steps

#### Step 1: Download Ubuntu ISO

Download the Ubuntu Desktop ISO from the official Ubuntu website.

#### Step 2: Create a New VM

1. Open VirtualBox.

2. Click **New**.
3. Enter a name such as:

Ubuntu-VAPT-Lab

4. Select the Ubuntu ISO file.
5. Select the appropriate Linux/Ubuntu operating-system type if prompted.
6. Allocate at least **2048 MB (2 GB) RAM**.
7. Create a virtual hard disk.
8. Select **20 GB or more** as the virtual disk size.
9. Finish creating the VM.

### Recommended Configuration

Name: Ubuntu-VAPT-Lab

RAM: 2048 MB or more

Storage: 20 GB or more

Operating System: Ubuntu Linux

### Screenshot

Take a screenshot of the VM configuration showing the allocated RAM and storage.

**Screenshot 2:** *Ubuntu VM configuration in VirtualBox.*

### Observation

A new virtual machine was created with Ubuntu selected as the guest operating system. The VM was configured with at least 2 GB of RAM and 20 GB of virtual storage.

---

## Task 3: Start Ubuntu VM

### Objective

Start the Ubuntu virtual machine and verify that the Ubuntu desktop runs successfully.

### Steps

1. Open VirtualBox.
2. Select the created Ubuntu VM.
3. Click **Start**.

4. Allow the VM to boot from the Ubuntu ISO.
5. Follow the Ubuntu installation instructions if Ubuntu has not already been installed.
6. Complete the installation.
7. Restart the VM when requested.
8. Log in to Ubuntu.
9. Confirm that the Ubuntu desktop is running inside the VM window.

### Screenshot

Take a screenshot showing the **Ubuntu desktop running inside the VirtualBox VM window**.

**Screenshot 3:** *Ubuntu Linux desktop running inside the virtual machine.*

### Observation

Ubuntu successfully started inside the virtual machine. The guest operating system was running independently inside the VirtualBox environment while the host operating system remained available.

---

## Task 4: Type 1 vs Type 2 Hypervisors

### Three Differences

| Feature      | Type 1 – Bare Metal                        | Type 2 – Hosted                                           |
|--------------|--------------------------------------------|-----------------------------------------------------------|
| Installation | Runs directly on physical hardware         | Runs on top of an existing operating system               |
| Performance  | Generally has less virtualization overhead | Has additional overhead because it depends on the host OS |
| Typical Use  | Common in servers and data centers         | Common on desktops, laptops, and development systems      |

### Real-World Examples

#### Type 1: VMware ESXi

VMware ESXi is a bare-metal hypervisor designed to run virtual machines directly on physical server hardware.

#### Type 2: Oracle VirtualBox

VirtualBox runs as an application on an existing operating system such as Windows, Linux, or macOS and is therefore a Type 2 hypervisor.

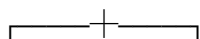
### Simple Diagram

TYPE 1 – BARE METAL

Physical Hardware



Hypervisor



VM 1 VM 2 VM 3

TYPE 2 – HOSTED

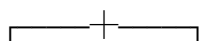
Physical Hardware



Host Operating System



VirtualBox



VM 1 VM 2 VM 3

---

## Final Conclusion

Virtualization allows multiple operating systems to run on the same physical computer through virtual machines. In this practical exercise, VirtualBox was used to create a virtual machine and configure Ubuntu Linux with at least 2 GB of RAM and 20 GB of storage.

The exercise also demonstrated the difference between Type 1 and Type 2 hypervisors. Type 1 hypervisors run directly on physical hardware and are commonly used in server environments, while Type 2 hypervisors run on top of an existing operating system and are commonly used on personal computers for learning, testing, and development.

## Screenshots Required

### Screenshot What to Capture

1 VirtualBox successfully installed / Manager opened

## **Screenshot What to Capture**

- 2**            Ubuntu VM configuration showing  $\geq 2$  GB RAM and  $\geq 20$  GB storage
- 3**            Ubuntu desktop running inside the VM

## Assignment: Cloud Computing Basics and AWS

### Theory: Introduction to Cloud Computing

#### What is Cloud Computing?

Cloud computing is the delivery of computing resources such as **servers, storage, databases, networking, and applications over the Internet**. Instead of purchasing and maintaining physical hardware, users can obtain computing resources from cloud providers when needed.

Examples of major cloud providers include:

- Amazon Web Services (AWS)
- Microsoft Azure
- Google Cloud Platform (GCP)

#### Benefits of Cloud Computing

1. **Scalability** – Resources can be increased or decreased according to demand.
  2. **Cost efficiency** – Organizations can avoid purchasing large amounts of physical infrastructure.
  3. **Accessibility** – Cloud resources can be accessed over the Internet.
  4. **Flexibility** – Different computing resources can be provisioned according to requirements.
  5. **Reliability** – Cloud providers offer infrastructure designed for high availability and resilience.
- 

#### Cloud Service Models

The three traditional cloud service models are **IaaS, PaaS, and SaaS**. AWS describes them as different levels of responsibility and control over the underlying infrastructure.

#### Task 1: Comparison of IaaS, PaaS and SaaS

| Feature                   | IaaS                                      | PaaS                                            | SaaS                                  |
|---------------------------|-------------------------------------------|-------------------------------------------------|---------------------------------------|
| Full Form                 | Infrastructure as a Service               | Platform as a Service                           | Software as a Service                 |
| What is provided?         | Virtual servers, storage and networking   | Application development and deployment platform | Complete software application         |
| User manages              | OS, applications, data and configurations | Application code and data                       | Mainly application usage and settings |
| Infrastructure management | Mostly cloud provider                     | Cloud provider                                  | Cloud provider                        |

| Feature       | IaaS                                 | PaaS                  | SaaS                  |
|---------------|--------------------------------------|-----------------------|-----------------------|
| Main users    | System administrators and developers | Software developers   | End users             |
| Control level | High                                 | Medium                | Low                   |
| Example       | Amazon EC2                           | AWS Elastic Beanstalk | Gmail / Microsoft 365 |

## Real-World Examples

### IaaS – Amazon EC2:

Amazon EC2 provides virtual computing resources that users can configure and use to run applications.

### PaaS – AWS Elastic Beanstalk:

Elastic Beanstalk provides a platform for deploying applications without requiring the user to manage the underlying infrastructure.

### SaaS – Spotify:

Spotify provides a complete software service through the Internet. Users simply use the application without managing its servers or underlying infrastructure.

## Simple Explanation

**IaaS:** Rent the infrastructure.

**PaaS:** Use a platform to build and deploy applications.

**SaaS:** Use the finished application.

## Task 2: Cloud Computing in Daily-Use Apps

### 1. Zomato

Zomato can use cloud computing to host its application servers, databases, APIs, and other backend services. Cloud infrastructure can also help handle changes in demand when many users are simultaneously searching for restaurants or placing orders.

### 2. Instagram

Instagram can use cloud computing to store and process large amounts of photos, videos, messages, and user information. Cloud infrastructure can also provide scalable computing and storage resources to support large numbers of users.

## Conclusion

Cloud computing allows applications such as Zomato and Instagram to operate backend infrastructure without relying entirely on physical servers owned and maintained by the application company.

### Task 3: Create an AWS Account and Open the AWS Console

#### Objective

Create an AWS account using your own details and access the AWS Management Console.

#### Steps

1. Visit the official **AWS website**.
2. Select **Create an AWS Account**.
3. Enter your own email address and account information.
4. Complete the required verification steps.
5. Sign in to the **AWS Management Console**.
6. Search for **EC2** in the AWS services/search bar.
7. Open the EC2 dashboard.
8. Confirm that your AWS account and console are working.

#### Screenshot Required

Take a screenshot showing the AWS Management Console/dashboard with your account information visible as required by your assignment.

**Screenshot 1:** *AWS Management Console/dashboard.*

#### Important

Use **your own email address and phone number**. Do not use randomly generated account details.

---

### Task 4: Launch a Basic EC2 Instance

#### Objective

Launch a basic Linux EC2 instance using the AWS Free Tier/credits where eligible.

#### Important AWS Free Tier Note

AWS changed its Free Tier structure for new customers starting **July 15, 2025**. New AWS customers can receive Free Tier credits, and eligibility depends on the account and current AWS Free Tier terms. AWS's current documentation also provides specific instance types that may be eligible under the applicable Free Tier benefits.

Therefore, **check the Free Tier eligibility label displayed in your own AWS console before launching the instance**.

#### Steps

1. Sign in to the AWS Management Console.
2. Search for **EC2**.
3. Open **EC2 Dashboard**.
4. Select **Launch instance**.
5. Enter a name such as:

Cloud-Lab-EC2

6. Under **Application and OS Images**, select a Linux AMI.
7. For this assignment, use **Amazon Linux** if the required option is available and marked Free Tier eligible.
8. Select an eligible small instance type.
9. Create or select a key pair if you plan to connect to the instance.
10. Review the network and storage settings.
11. Make sure you understand the pricing/Free Tier status shown by AWS.
12. Click **Launch instance**.

AWS's current EC2 documentation describes this launch flow: choose the region, select **Launch instance**, choose an AMI, select the instance type, configure the key pair/network/storage, and then launch.

### **Screenshot Required**

After launching the instance:

1. Go to **EC2 → Instances**.
2. Select your newly created instance.
3. Wait until its state becomes **Running**.
4. Open the instance details.

Take a screenshot showing:

- Instance ID
- Instance state
- Instance type
- Public IPv4 address, if assigned
- AMI/OS information

**Screenshot 2:** *EC2 instance details showing the instance in the Running state.*

## Observation

The EC2 instance was successfully launched using the AWS Management Console. The instance details page provides information about its state, instance type, networking, and other configuration parameters.

---

## Task 5: Stop the EC2 Instance and Check Its Status

### Objective

Stop the EC2 instance and verify that its state changes from **Running** to **Stopped**.

### Steps

1. Go to **EC2 → Instances**.
2. Select the instance created in Task 4.
3. Click **Instance state**.
4. Select **Stop instance**.
5. Confirm the action.
6. Wait for the instance state to change from:

Running

↓

Stopping

↓

Stopped

7. Refresh the page if necessary.
8. Take a screenshot showing the final **Stopped** state.

AWS states that a stopped EC2 instance does not incur instance usage or data-transfer charges, although storage volumes such as EBS can continue to incur charges.

### Screenshot Required

**Screenshot 3:** *EC2 instance details showing the instance state as Stopped.*

### Important Cost/Safety Note

Do not leave cloud resources running unnecessarily. AWS specifically notes that EC2 instance usage is charged while an instance is in the **Running** state, subject to applicable Free Tier/credits.

If you no longer need the instance, consider **terminating** it rather than simply stopping it, while understanding that termination is different from stopping and can delete the instance's associated root storage depending on its configuration.

---

## Screenshot Checklist

### Screenshot   Required Evidence

**Screenshot 1** AWS Management Console/dashboard with your account information

**Screenshot 2** EC2 instance details showing **Running** state

**Screenshot 3** EC2 instance details showing **Stopped** state

---

## Final Conclusion

Cloud computing provides on-demand access to computing resources such as servers, storage, networking, and applications through the Internet. The major service models are **IaaS, PaaS, and SaaS**, which provide different levels of control and responsibility.

In the practical portion, an AWS account was used to access the AWS Management Console and launch an **Amazon EC2** virtual server. The instance was then monitored through the EC2 console and stopped after the practical exercise.

This practical demonstrated how cloud platforms can provide computing resources without requiring users to purchase and maintain physical servers.

## Assignment: AWS S3 Storage and IAM

### Theory

#### Key Cloud Concepts

Cloud computing provides several important services for storing, processing, and protecting data.

- **Storage:** Services such as Amazon S3 provide scalable cloud storage for files and objects.
- **Databases:** Cloud databases can store application data without requiring organizations to maintain physical database servers themselves.
- **Networking:** Cloud networking connects applications, servers, users, and other cloud resources.
- **Security:** Cloud platforms provide security mechanisms such as Identity and Access Management (IAM) to control who can access resources.

#### What is IAM?

**AWS Identity and Access Management (IAM)** is used to control access to AWS resources. IAM policies define which actions an identity can perform on particular resources. AWS recommends the principle of **least privilege**, meaning users should receive only the permissions necessary for their tasks.

---

### Task 1: Create an S3 Bucket and Upload a File

#### Objective

Create a new Amazon S3 bucket and upload an image or PDF file.

#### Steps

1. Log in to the **AWS Management Console**.
2. Search for **S3**.
3. Open **Amazon S3**.
4. Click **Create bucket**.
5. Enter a globally unique bucket name.

Example:

swiggy-files-2026-demo

**Note:** S3 bucket names must be unique, so choose your own available name.

6. Select the appropriate AWS Region.
7. Keep **Block all public access** enabled unless the assignment specifically requires public access.
8. Acknowledge the settings.

9. Click **Create bucket**.
10. Open the newly created bucket.
11. Click **Upload**.
12. Select any image or PDF from your computer.
13. Click **Upload**.

### Example Bucket Structure

swiggy-files-2026-demo

```
|  
└─ sample.pdf
```

### Screenshot

**Screenshot 1:** S3 bucket showing the uploaded image/PDF.

### Observation

The S3 bucket was successfully created and a sample file was uploaded to cloud storage.

---

## Task 2: Create a Folder Structure in S3

### Objective

Create folders that represent the structure of a music-streaming application such as Spotify.

### Folder Structure

swiggy-files-2026-demo

```
|  
└─ albums/  
    └─ album-sample.pdf  
|  
└─ artists/  
    └─ artist-sample.pdf  
|  
└─ playlists/  
    └─ playlist-sample.pdf
```

## Steps

1. Open the S3 bucket created in Task 1.
2. Click **Create folder**.
3. Create:

albums

4. Create another folder:

artists

5. Create another folder:

playlists

6. Open each folder.
7. Upload at least one sample file into each folder.

## Screenshot

**Screenshot 2:** S3 bucket showing the albums, artists, and playlists folders.

## Observation

The S3 bucket was organized into separate prefixes/folders representing albums, artists, and playlists. Each folder contained at least one sample file.

---

## Task 3: Create the zomatoUploader IAM User

### Objective

Create an IAM user that can **upload and list objects** in the S3 bucket but cannot download or delete them.

AWS's S3 policy examples show that s3:ListBucket applies to the bucket itself, while s3:PutObject applies to objects inside the bucket.

### Step 1: Create IAM User

1. Open the AWS Management Console.
2. Search for **IAM**.
3. Open **IAM**.
4. Go to **Users**.
5. Click **Create user**.
6. Enter:

Username: zomatoUploader

7. Configure console access if your practical requires the user to log in through the AWS Console.
8. Continue to permissions.

---

## Step 2: Create a Custom IAM Policy

Create a customer-managed policy and use the following policy.

Replace:

YOUR-BUCKET-NAME

with your actual S3 bucket name.

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "AllowListBucket",
      "Effect": "Allow",
      "Action": [
        "s3:ListBucket"
      ],
      "Resource": "arn:aws:s3:::YOUR-BUCKET-NAME"
    },
    {
      "Sid": "AllowUploadObjects",
      "Effect": "Allow",
      "Action": [
        "s3:PutObject"
      ],
      "Resource": "arn:aws:s3:::YOUR-BUCKET-NAME/*"
    }
  ]
}
```

```
]
}
```

### What This Policy Allows

| Action                 | Permission    |
|------------------------|---------------|
| List objects in bucket | ✅ Allowed     |
| Upload objects         | ✅ Allowed     |
| Download objects       | ❌ Not allowed |
| Delete objects         | ❌ Not allowed |

The policy follows the least-privilege principle by granting only the two S3 actions required for this assignment. AWS recommends granting only the permissions required for a task.

### Important Console Note

The AWS S3 console can require additional permissions for some navigation features. AWS documents that console-based S3 access can require permissions beyond the basic API permissions.

For this assignment, the important security test is that **PutObject succeeds while GetObject and DeleteObject are not permitted.**

---

### Task 4: Test the IAM Permissions

#### Objective

Log in as zomatoUploader and test which S3 operations are permitted.

#### Test 1: List Files

Log in as:

zomatoUploader

Open S3 and access the assigned bucket.

#### Expected Result:

List operation → Allowed ✅

The user should be able to see/list objects if the console path works with the granted permissions.

---

### Test 2: Upload a File

Select **Upload** and upload a small test file.

Example:

test-upload.txt

**Expected Result:**

**Upload → Allowed** 

This works because the policy grants:

s3:PutObject

---

**Test 3: Download a File**

Try downloading one of the existing objects.

**Expected Result:**

**Download → Denied** 

The policy does not grant:

s3:GetObject

---

**Test 4: Delete a File**

Try deleting the uploaded test file.

**Expected Result:**

**Delete → Denied** 

The policy does not grant:

s3:DeleteObject

---

**Results Table**

| Operation     | Expected Result                                                                             | Reason                     |
|---------------|---------------------------------------------------------------------------------------------|----------------------------|
| List files    |  Allowed | s3:ListBucket              |
| Upload file   |  Allowed | s3:PutObject               |
| Download file |  Denied  | No s3:GetObject permission |

| Operation   | Expected Result                                                                          | Reason                        |
|-------------|------------------------------------------------------------------------------------------|-------------------------------|
| Delete file |  Denied | No s3:DeleteObject permission |

## Screenshot

**Screenshot 3:** Upload successfully completed.

**Screenshot 4:** Access denied/error message when attempting to delete or download.

## Observation

The IAM policy successfully restricted the user's permissions. The zomatoUploader user could upload and list objects but did not have permissions to download or delete objects.

## Task 5: Importance of IAM in Cloud Security

### Short Note

IAM plays an important role in protecting data in cloud applications such as Paytm or PhonePe. It allows organizations to control which users, applications, and services can access specific cloud resources. IAM policies can restrict users to only the actions they need, following the principle of least privilege. This reduces the impact of compromised credentials or accidental misuse. AWS also recommends regularly reviewing and removing unnecessary users and permissions.

### Real-World Example

A well-known example is the **2019 Capital One cloud data breach**. According to the U.S. Department of Justice, the intrusion involved a misconfigured web application firewall that enabled access to stored data, and the attacker used access associated with a cloud role to enumerate and extract data.

The incident demonstrates why cloud access controls, configuration, monitoring, and least-privilege permissions are important. AWS recommends restricting identities to only the permissions required for their tasks and regularly reviewing permissions.

### Final Conclusion

Amazon S3 provides scalable cloud object storage, while IAM provides access control over AWS resources. In this practical exercise, an S3 bucket was created and organized into albums, artists, and playlists folders.

An IAM user named zomatoUploader was then configured with limited S3 permissions. The user could **list and upload files**, while **download and delete operations were denied**. This demonstrates the principle of least privilege and shows how IAM policies can help protect cloud data.

### Screenshot Checklist

### Screenshot Evidence

## **Screenshot Evidence**

- 1** S3 bucket with uploaded image/PDF
- 2** albums, artists, playlists folders
- 3** Successful upload using zomatoUploader
- 4** Download/delete permission denied